SAMPLE / FOR TESTING ONLY

Information Security Policy

KnowFlow Technologies LLC

Fictional policy document prepared solely for testing information retrieval and document-grounded question answering. It is not an approved or operative corporate policy.

Document ID	KF-SEC-POL-001
Version	1.0 sample
Issued	13 October 2026
Policy owner	Fictional Security Office
Review cycle	Annual
Classification	Internal sample

This document contains fictional control statements. All names, processes, timelines, and contact routes are invented for evaluation.

1. Purpose, scope, and governance

This policy describes baseline safeguards for information and technology used by KnowFlow Technologies LLC (KnowFlow). Its purpose is to reduce unauthorized access, loss, alteration, disclosure, and disruption of company information.

1.1 Applicability

The requirements apply to employees, interns, temporary personnel, consultants, service providers, and other parties who use KnowFlow information, facilities, accounts, devices, applications, or networks. Business unit procedures may add stricter safeguards but may not weaken this policy.

1.2 Governance and exceptions

- Business leaders are accountable for identifying information owners and ensuring that safeguards are used in their areas.
- The Security Office maintains this policy, coordinates security risk reviews, and advises on safeguards. Technology Operations implements technical controls.
- An exception requires a written risk statement, named accountable owner, compensating safeguards, expiration date, and approval from the Security Office and the relevant business leader before the exception begins.
- Exceptions are reviewed at least every six months and must be renewed before expiry. Expired exceptions cease to be authorized.

1.3 Awareness and compliance

Personnel must complete security awareness training when joining and at least once each calendar year. Role-specific training is assigned to people with elevated duties or access to sensitive information. Managers address overdue training with the relevant person and People Operations.

Suspected violations are reported through the security incident route in Section 7. KnowFlow may restrict access while it assesses a concern. Contractual, legal, or employment actions are handled by authorized company functions.

1.4 Terms used

Information asset means data, software, equipment, credentials, or services used to conduct company work. **Privileged account** means an identity permitted to change security settings, administer systems, or access broad sets of records. **Third party** means an external organization or person acting under an arrangement with KnowFlow.

2. Identity and access management

2.1 Individual identities

Each person must use a uniquely assigned identity for routine work. Shared identities are prohibited except for documented technical services or an approved operational exception. A service identity must have a named owner, a defined purpose, restricted permissions, and credentials held in an approved secrets store.

2.2 Granting and changing access

- A manager or information owner requests access through the approved access workflow and identifies the business purpose, systems, data scope, and required end date when known.
- The system or data owner authorizes access before provisioning. Access is limited to the minimum functions and information needed for assigned duties.
- Changes in role, project, or contract trigger a review of existing entitlements. Access that is no longer justified is removed promptly.
- High-impact production changes require a separate authorized identity and a recorded change ticket. Routine user identities must not be used to administer production infrastructure.

2.3 Privileged user access

Privileged user access is assigned only to designated personnel whose duties require it. The system owner approves each assignment, and the Security Office reviews the approved privileged access register at least once every three months. Each review confirms the named person, business need, assigned scope, and continued authorization; unjustified access is withdrawn and the review outcome is recorded.

- Where technically supported, elevated permissions are activated for a limited task period and are not used for routine email or web browsing.
- Administrative actions use a distinct privileged identity with stronger authentication and centralized event recording.
- Emergency access is recorded with the reason, approver, start and end time, and actions taken. The system owner reviews the record on the next business day.

2.4 Periodic access recertification

Information owners recertify access to business applications and repositories at least every six months. High-sensitivity data stores are recertified quarterly. The owner documents approval, removal requests, and unresolved items; unresolved access is escalated to the business leader and closed within ten business days.

3. External access, authentication, and passwords

3.1 Third-party connectivity

Third-party remote access requires written approval from the Information Security function before activation. The business sponsor and system owner must define the work purpose, permitted resources, named external users, access window, and contract end date. Connectivity is disabled when the approved task ends or the arrangement expires.

- Remote sessions use an approved encrypted connection and multi-factor authentication. Direct exposure of administrative interfaces to the public internet is prohibited.
- External identities are individually attributable; generic vendor accounts are not permitted for interactive access.
- The sponsor confirms at least quarterly that external access remains necessary and that named users still require it.
- KnowFlow personnel must supervise high-risk maintenance sessions and retain the associated change or service record.

3.2 Authentication

Multi-factor authentication is required for remote access, privileged accounts, and systems containing confidential or restricted information. Approved factors must be bound to an individual. Authentication secrets must not be shared, sent in ordinary email, or stored in unprotected documents.

3.3 Passwords and secrets

- When a password is used, it must be at least 14 characters long or a passphrase of equivalent strength, unique to the KnowFlow account, and resistant to common or known-compromised values.
- Password managers approved by Technology Operations may be used to create and store unique credentials. Reuse of a company password on a personal or unrelated service is prohibited.
- Passwords are changed promptly if compromise is suspected or confirmed; routine forced rotation is applied only where a system or risk requirement calls for it.
- Default and temporary credentials are replaced before a system or account is put into normal use. Temporary credentials expire or are reset at first sign-in.
- Recovery codes and cryptographic secrets are protected with controls at least as strong as the systems they unlock.

3.4 Lockout and unattended sessions

Systems must slow or block repeated failed sign-in attempts using a risk-appropriate threshold. Devices and sessions are locked when unattended. Sensitive applications end inactive sessions after a defined period, normally no longer than 15 minutes.

4. Workforce changes and physical security

4.1 Joining, transfer, and departure

People Operations notifies the manager and Technology Operations of confirmed personnel changes through the designated workflow. Managers return company assets and identify records that need reassignment. System owners remove or revise access based on the person’s role and information responsibilities.

User credentials must be disabled no later than the employee’s effective termination time. For an involuntary separation or an urgent security concern, the manager coordinates a timed access suspension with People Operations and Technology Operations. External accounts are disabled by contract end or earlier when the sponsor ends the engagement.

4.2 Physical entry

- Entry to offices and equipment rooms is limited to authorized people. Visitors sign in, display a visitor badge, and remain with a host in controlled areas.
- Access badges are personal property and may not be loaned or used to admit another person. Lost badges are reported promptly to Facilities.
- Equipment rooms and network closets remain locked. Entry records are retained for at least 90 days unless a longer period is required for an investigation.
- Screens and printed materials containing confidential information are not left visible in public or shared areas.

4.3 Clear workspace and equipment

Personnel secure paper records in locked storage when unattended and dispose of them using approved confidential waste containers. Company equipment is stored securely during travel and must not be left in a vehicle overnight. Equipment leaving a controlled site is recorded when required by the asset owner.

4.4 Asset inventory

Technology Operations maintains an inventory of managed endpoints, servers, network equipment, and material cloud services. Each record identifies an accountable owner, location or hosting environment, lifecycle state, and sensitivity where applicable. Inventory accuracy is checked at least annually and when equipment is issued, transferred, or retired.

5. Information handling and endpoint safeguards

5.1 Information categories

Information owners classify records according to the harm that unauthorized disclosure or alteration could cause. KnowFlow uses three handling levels: **Public**, approved for general release; **Internal**, intended for company work; and **Restricted**, whose exposure could create significant customer, legal, financial, or operational harm.

5.2 Handling requirements

- Public information may be distributed after the relevant owner approves its release.
- Internal information is shared through company-managed services with people who have a work need. It is not posted to public sites or personal accounts.
- Restricted information is accessible only to specifically authorized people, transmitted through approved encrypted services, and stored in locations with access logging and controlled sharing.
- Before sending sensitive records to an external recipient, the sender verifies the recipient and uses an approved transfer method. Unneeded data fields are removed where practical.
- Information owners set retention periods based on business and legal requirements. Records past their approved retention period are securely deleted or archived under an authorized schedule.

5.3 Endpoint configuration

Company-managed endpoints use supported operating systems, full-disk encryption, centrally managed endpoint protection, and automatic security updates. Users must not disable protective agents or bypass device management. Unsupported devices are removed from company access until remediated or formally excepted.

5.4 Removable media

Use of removable storage is disabled by default on managed endpoints. A business need requires written approval from the information owner and Technology Operations. Approved media must be company-issued, encrypted, malware-scanned before use, inventoried when assigned, and securely erased or physically destroyed when retired. Restricted information may not be copied to removable media unless the Security Office approves a documented exception.

5.5 Disposal and reuse

Storage media and devices are sanitized using a method appropriate to their sensitivity before reuse, return, or disposal. If reliable sanitization is not possible, the media is physically destroyed by an approved provider and the disposal record is retained.

6. Logging, monitoring, and vulnerability management

6.1 Event records

Systems that process company information record security-relevant events, including successful and failed authentication, privileged actions, access changes, security configuration changes, and material data exports. Records include a timestamp, event type, source, and associated identity where available.

- Logs are forwarded to a centrally managed service when the system supports it and are protected against unauthorized alteration or deletion.
- System clocks use an approved time source and remain synchronized. Administrators do not alter log timestamps or disable required audit settings without an approved change.
- Security event records are retained for at least 180 days, with at least 90 days readily searchable. Longer retention applies when a legal hold or documented risk requirement exists.
- Access to logs is restricted to authorized operational, security, and audit personnel. Queries involving personnel activity are handled for a defined security or compliance purpose.

6.2 Monitoring and review

The Security Office monitors alerts for suspicious sign-ins, unexpected privilege changes, malware detections, and unusual data movement. High-severity alerts are triaged within one hour; other actionable alerts are reviewed by the end of the next business day. Investigation outcomes and tuning decisions are recorded.

6.3 Vulnerability and patch management

Technology Operations scans managed infrastructure at least monthly and after material changes. Critical vulnerabilities exposed to the internet are remediated or mitigated within 14 calendar days; other critical issues within 30 days; high-severity issues within 60 days. A system owner documents a compensating measure and target date when the normal deadline cannot be met.

6.4 Secure changes

Changes to production systems are requested, risk-assessed, approved, tested where feasible, and recorded before implementation. Emergency changes may be completed to restore service or contain a threat, with retrospective approval and record completion by the next business day. Developers and reviewers are separated for high-impact changes where staffing permits.

7. Security incident reporting and response

7.1 Reporting

Anyone who suspects a lost device, exposed credential, misdirected sensitive record, malicious software, unauthorized access, or other security event must report it immediately through the Security Office incident portal or the designated on-call telephone route. If neither route is available, notify the manager and Technology Operations without delay.

Reports should state what happened, when it was noticed, affected systems or records, actions already taken, and a way to contact the reporter. Reporters should preserve relevant messages and evidence, avoid altering affected systems, and follow responder instructions.

7.2 Response

- The Security Office assigns severity, opens an incident record, identifies an incident lead, and coordinates containment, investigation, recovery, and communications.
- For a suspected active compromise, responders may isolate affected devices or accounts, revoke tokens, block network paths, or preserve system images.
- Only authorized company representatives communicate externally about an incident. Legal, privacy, customer, and regulatory notifications are assessed by the appropriate functions.
- Incident evidence is handled with a documented chain of custody when it may support legal, regulatory, or disciplinary action.
- After a significant incident, the incident lead records root causes, impact, response timeline, lessons learned, and corrective actions with owners and due dates.

7.3 Exercise and readiness

The Security Office conducts a tabletop response exercise at least annually and tests the contact tree at least twice per year. Technology Operations maintains current escalation contacts and recovery dependencies for critical services.

7.4 Protection of reporters

Personnel are expected to report concerns promptly and in good faith. A person should not delay reporting while trying to prove that an event is a security incident.

8. Backups, recovery, and resilience

8.1 Backup requirements

Technology Operations defines a backup schedule for each critical service with its owner. Critical business data is backed up at least daily. Backup copies are encrypted in transit and at rest, access is limited to designated operators, and at least one copy is logically or physically separated from the production environment.

- Backup jobs generate status records. Failed jobs affecting critical services are investigated by the next business day and rerun or covered by an approved alternative.
- Backup retention follows the service owner’s approved schedule and applicable records requirements. Backup media or cloud copies are protected against unauthorized deletion.
- Backup administration uses privileged identities and multi-factor authentication. Backup credentials are not reused as production service credentials.

8.2 Recovery objectives

Service owners document recovery priorities and dependencies. Unless a service-specific plan sets stricter objectives, critical services target a recovery time of 24 hours and a recovery point of 24 hours. The owner records any accepted gap between these targets and business needs.

8.3 Restore testing

Technology Operations performs a sample restoration for each critical service at least quarterly. At least annually, the service owner participates in a recovery exercise that verifies data integrity, access controls, and operational readiness. Results, elapsed recovery time, defects, and corrective actions are recorded.

8.4 Continuity arrangements

Critical service owners maintain a continuity plan for loss of a primary site, cloud region, or key supplier. Plans identify alternate ways to deliver priority work, decision authority, communications, and dependencies that must be restored first. Material plans are reviewed annually and after significant changes.

8.5 Supplier resilience

Before relying on an external service for critical operations, the business sponsor assesses service continuity commitments, data return or deletion, incident notification, and exit arrangements. Reviews are repeated at renewal or after a significant service change.

9. Network, application, and supplier safeguards

9.1 Network protection

- Networks are segmented according to function and sensitivity. Access between segments is limited to documented business flows.
- Wireless networks use approved encryption and authentication. Guest connectivity is separated from company systems.
- Firewall and cloud security rules have an owner and documented purpose. Unused rules are removed during periodic review.
- Public-facing services use supported encryption protocols and are protected against common traffic abuse where appropriate.

9.2 Application security

Applications that handle company information are reviewed for security risks before production use and after material changes. Development teams protect source code and build credentials, review code changes, and address discovered weaknesses according to severity. Production data is not copied into development environments unless it is masked or an approved exception is in place.

9.3 Supplier assurance

Business sponsors assess suppliers that store, process, transmit, or can access KnowFlow information before onboarding and at renewal. The assessment considers data sensitivity, access scope, security practices, subcontractors, incident notice, and service continuity. Contract terms define confidentiality, permitted use, breach cooperation, and return or deletion of information at exit.

9.4 Data exchange

Interfaces and recurring data transfers have an accountable owner, documented source and destination, defined fields, and a business purpose. Owners periodically validate that the exchange remains necessary and that failed transfers do not leave unprotected copies.

9.5 Cryptography

Approved cryptographic methods protect Restricted information at rest and sensitive information in transit over untrusted networks. Cryptographic keys are access-controlled, rotated or replaced when compromised, and retired when no longer needed. Keys are stored separately from the data they protect when the platform supports separation.

10. Privacy, records, and policy maintenance

10.1 Personal information

Personal information is collected and used for a stated business purpose, limited to what is necessary, and accessible only to authorized personnel. Teams consult the privacy lead before launching a materially new use, combining datasets in a new way, or sharing personal information with a new external party.

10.2 Records and legal holds

Business records are retained and disposed of under the approved records schedule. A legal hold, investigation hold, or other preservation instruction overrides ordinary deletion schedules for the records within its scope. Personnel must not destroy or alter records subject to a preservation instruction.

10.3 Reviews and assurance

Control owners provide evidence of operation when requested by the Security Office or an authorized auditor. The Security Office reviews this policy at least annually and after a major incident, material technology change, or significant change in business risk. Revisions are approved by the fictional executive sponsor and communicated to affected personnel.

10.4 Responsibilities at a glance

Personnel	Protect credentials and information; complete training; report suspected events promptly.
Managers	Request and review access; communicate role changes; ensure personnel follow safeguards.
Information owners	Classify records; approve access; recertify entitlements; define retention and sharing.
Technology Operations	Configure and maintain technical safeguards; manage access implementation; operate backup and logging controls.
Security Office	Maintain policy; review privileged access; coordinate incident response, monitoring, and exceptions.
Business sponsors	Assess supplier need and risk; sponsor external access; coordinate termination of supplier access.

Policy status: SAMPLE / FOR TESTING ONLY. This fictional policy does not create actual obligations or a real incident contact route.